

PROJETO DE CONSULTORIA BLUE TEAM - LOJAZETA

Ingrid Soares
Formação em Cybersegurança
Vai na Web & Kensei Cybersec (2025)

*Documento Técnico de Arquitetura, Monitoramento e
Resposta a Incidentes*

1. Sumário Executivo

A LojaZeta, um e-commerce em expansão, enfrenta um aumento significativo no volume e na complexidade de ataques cibernéticos, incluindo tentativas de SQL Injection (SQLi), Cross-Site Scripting (XSS) e ataques de força bruta direcionados à rota */login*. A ausência de controles consolidados de segurança, como práticas adequadas de defesa em profundidade e monitoramento centralizado, expõe a empresa a riscos operacionais, financeiros e reputacionais.

Este relatório apresenta uma proposta técnica estruturada para elevar a maturidade de segurança da LojaZeta. A solução é fundamentada no modelo de defesa em profundidade, incorpora monitoramento centralizado com o SIEM Wazuh, estabelece procedimentos formais de Resposta a Incidentes alinhados ao NIST 800-61 e organiza a implementação por meio de um roadmap estratégico baseado no princípio 80/20, priorizando ganhos rápidos nos primeiros 30 dias.

Ao final da execução desse plano, a LojaZeta estará apta a detectar, conter e responder a ameaças em tempo real, reduzindo a superfície de ataque e criando uma base sólida para o crescimento seguro do negócio.

2. Objetivo

O objetivo deste documento é apresentar uma proposta técnica e estratégica para fortalecer a segurança cibernética da LojaZeta. Especificamente, busca-se:

- estruturar uma arquitetura de defesa em profundidade adequada ao contexto do e-commerce;
- definir um plano de monitoramento mínimo viável, escalável e alinhado às boas práticas de SIEM;
- estabelecer procedimentos formais de resposta a incidentes com base no NIST 800-61;
- recomendar controles priorizados conforme a disponibilidade de recursos e a maturidade da equipe.

3. Escopo

O escopo técnico da consultoria abrange os seguintes componentes do ambiente:

Aplicação e Infraestrutura

Nginx, Node.js, PostgreSQL, VPC, Security Groups, Load Balancer.

Identidade e Acesso

Gerenciamento de credenciais, autenticação multifator (MFA) e controles de IAM.

Dados

Integridade, criptografia em repouso e em trânsito, bem como políticas de backup e restauração.

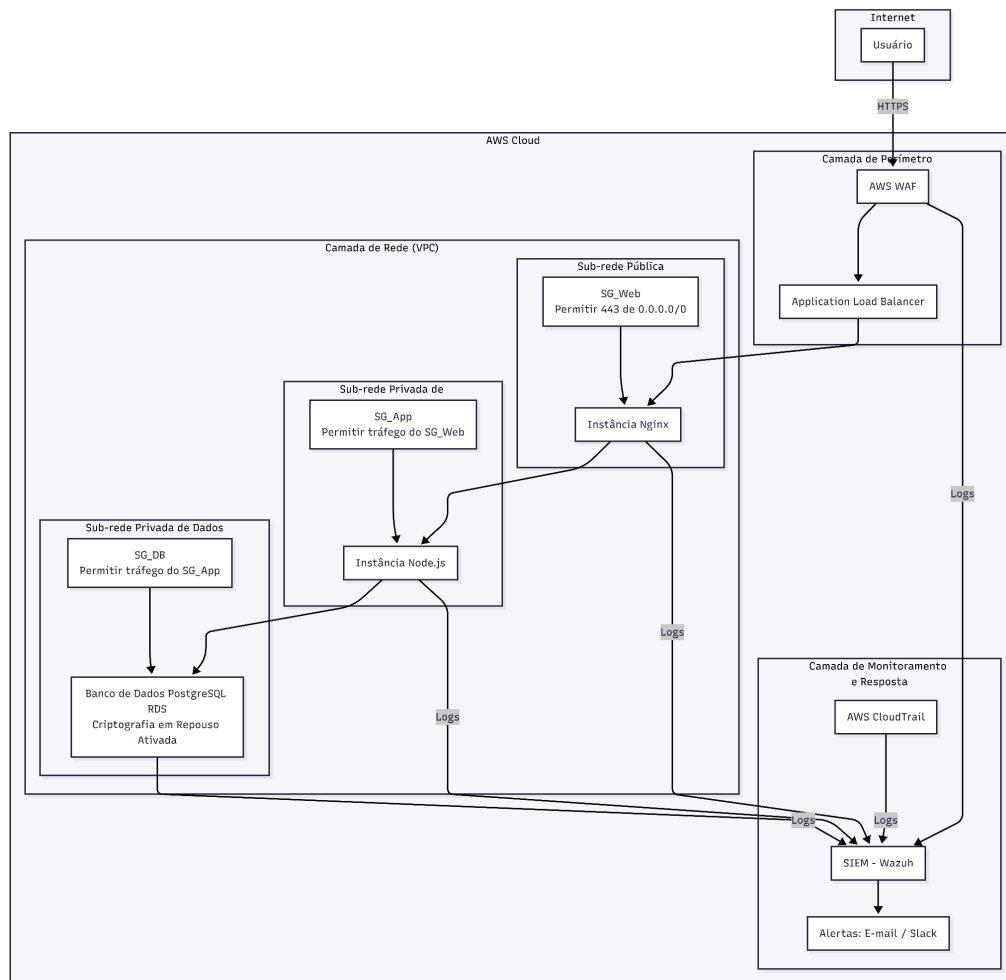
Monitoramento

Coleta estruturada de logs, análises, alertas, correlação e investigação de eventos.

Resposta a Incidentes

Processos formais, linhas de decisão, etapas operacionais e runbooks essenciais.

4. Diagrama da Arquitetura Proposta



5. Arquitetura de Defesa em Profundidade

A arquitetura proposta adota o modelo de camadas, garantindo que falhas individuais não comprometam a segurança global do ambiente. As camadas são descritas a seguir.

Camada de Perímetro

- Implementação de AWS WAF com regras gerenciadas para proteção contra SQLi, XSS e ataques automatizados.
- Configuração de rate limiting para mitigar ataques de força bruta contra a rota */login*.

Camada de Rede

- Segmentação da VPC em sub-redes públicas, privadas de aplicação e privadas de dados.
- Aplicação rigorosa de Security Groups seguindo o princípio de Zero Trust interno.

Camada de Host

- Automação de atualizações de segurança com AWS Systems Manager Patch Manager.
- Monitoramento de integridade de arquivos com AIDE.
- Implementação do ClamAV como solução antimalware de código aberto.

Camada de Aplicação

- Uso de ferramentas de SCA (Snyk) e SAST (SonarScanner).
- Code review estruturado com foco em segurança.
- Adoção obrigatória de prepared statements e ORM para prevenção de injeções.

Camada de Dados

- Criptografia AES-256 nativa do Amazon RDS.

- Testes trimestrais de restauração para validar a confiabilidade dos backups.

Camada de Identidade

- MFA obrigatório para todos os acessos administrativos.
- Revisão periódica de permissões no IAM, aplicando o princípio do menor privilégio.

6. Plano de Monitoramento e SIEM (Wazuh)

O monitoramento mínimo viável será realizado com o Wazuh, que oferece recursos essenciais para coleta, análise e correlação de eventos, além de alertas automatizados.

Fontes de Log

- Nginx (acesso e erro)
- Node.js (aplicação)
- PostgreSQL (auditoria)
- WAF (bloqueios e detecções)
- AWS CloudTrail (eventos de API)

Alertas Prioritários

- Tentativas de brute-force
- SQL Injection e XSS
- Criação suspeita de usuários IAM
- Alterações em arquivos críticos (AIDE)
- Instalação ou execução de binários maliciosos

KPIs de Segurança

- **MTTD** - Mean Time to Detect
- **MTTR** - Mean Time to Respond
- Percentual de logs coletados versus volume total de eventos

7. Plano de Resposta a Incidentes (NIST 800-61)

O plano segue o ciclo operacional recomendado pelo NIST 800-61:

1. Preparação

- Configuração completa do Wazuh e alertas.
- Documentação atualizada da arquitetura.
- Backups validados.

2. Detecção e Análise

- Verificação de logs correlacionados.
- Identificação de endereços IP maliciosos.
- Classificação do incidente por impacto e escopo.

3. Contenção

- Bloqueio de IPs ofensores.
- Isolamento de instâncias comprometidas.
- Revogação de credenciais expostas.

4. Erradicação

- Aplicação de patches corretivos.
- Remediação de vulnerabilidades.
- Remoção de artefatos maliciosos.

5. Recuperação

- Restauração segura dos serviços.

- Validação da integridade operacional.

6. Lições Aprendidas

- Elaboração de relatório pós-incidente.
- Ajustes no WAF, SIEM e código.
- Revisão de procedimentos internos.

8. Roadmap 80/20

Quick Wins - 30 Dias

- WAF com regras gerenciadas
- MFA obrigatório
- Criptografia do RDS habilitada
- Revisão de Security Groups

Em 3 Meses

- Wazuh implementado
- Automação de patching
- SAST + SCA no pipeline de CI/CD

Em 6 Meses

- File Integrity Monitoring (AIDE)
- Antimalware
- Testes recorrentes de restauração

Em 12 Meses

- SIEM avançado e consolidado
- Pentests periódicos
- Programa interno de conscientização

9. Riscos e Suposições

Riscos

- Orçamento reduzido
- Baixa maturidade inicial da equipe
- Dependência de ferramentas open source em ambiente crítico

Suposições

- Disponibilidade mínima da equipe técnica
- Ambiente pronto para implementação dos controles
- Apoio da diretoria na priorização das medidas de segurança

10. Conclusão

A aplicação deste projeto transformará a postura de segurança da LojaZeta de reativa para proativa. A combinação entre arquitetura robusta, monitoramento centralizado e processos institucionais de resposta a incidentes estabelece uma base confiável para suportar o crescimento da empresa.

Este documento demonstra capacidade técnica e estratégica na organização de um plano realista, executável e alinhado às necessidades de equipes com recursos limitados. A adoção das recomendações apresentadas proporcionará redução significativa de riscos e maior resiliência operacional frente ao cenário atual de ameaças.